

AXIOM Constitutional AI

OWASP LLM Top 10 | GDPR Art.30 | EU AI Act Art.13

Runtime Compliance Report - April 27, 2026

Every LLM response passes through four constitutional checkpoints before the caller sees it.

Destructive commands: blocked.

Injection attacks: blocked.

PII and credentials: redacted.

Persona overrides: blocked.

85 patterns enforced. Every block signed.

Every detection auditable. CANNOT_MUTATE - no agent can talk its way past this layer.

GDPR Article 30

OWASP LLM Top 10

EU AI Act Article 1

1. validate_output() - Four-Layer Architecture

Layer 1

DestructiveOperationGuard

OWASP LLM08

23 patterns | SQL drops, rm -rf, kubectl delete, terraform destroy, aws s3 rm

Action: **BLOCKED + human review**

Layer 2

OutputInjectionGuard

OWASP LLM02

32 patterns | XSS, SSRF, path traversal, command injection, SSTI, NoSQL

Action: **BLOCKED + human review**

Layer 3

PIIGuard

OWASP LLM06

30 patterns | SSN, cards, API keys, passwords, private keys, email, NPI, MRN

Action: **REDACTED in-place** | **GDPR Art.30 audit**

Layer 4

Compliance Signals

OWASP LLM01

16 signals | Constraint bypass, persona override, prompt injection keywords

Action: **BLOCKED**

2. OWASP LLM Top 10 - Coverage Matrix

ID	Title	Status	Control / Notes
LLM01	Prompt Injection	COVERED	Compliance signal layer + OutputInjectionGuard

LLM02	Insecure Output Handling	COVERED	OutputInjectionGuard - 32 patterns, 14/14 tests
LLM03	Training Data Poisoning	PARTIAL	Audit manifests; full runtime detection N/A
LLM04	Model Denial of Service	COVERED	DosWatcher - rate limits + circuit breaker
LLM05	Supply Chain Vulnerabilities	PARTIAL	HMAC-signed manifests; SBOM out of scope
LLM06	Sensitive Information Disclosure	COVERED	PIIGuard - 30 patterns, 12/12, GDPR Art.30
LLM07	Insecure Plugin Design	PARTIAL	Sandbox agent; formal plugin registry TBD
LLM08	Excessive Agency	COVERED	DestructiveOperationGuard - 23 patterns, 17/17
LLM09	Overreliance	PARTIAL	Uncertainty floor 0.15; calibration ongoing
LLM10	Model Theft	COVERED	CONSTITUTIONAL_SUFFIX prevents prompt/weight extraction

3. Guard Test Results

Guard	Ver	Patterns	Tests	Categories
DestructiveOperationGuard	v1.0	23	17/17	SQL, FS, Python, Cloud
PIIGuard	v1.0	30	12/12	CREDENTIALS, IDENTITY, FINANCIAL, CONTACT, MEDICAL
OutputInjectionGuard	v1.0	32	14/14	XSS, SSRF, PATH, CMD, SSTI, NoSQL
Compliance Signals	v1.0	16	pass	Bypass keywords, persona override, injection tokens
DosWatcher	v1.0	n/a	pass	Rate limit, burst, circuit breaker

4. Compliance Summary

Component	Result	Scope	Notes
OWASP LLM Top 10	6 / 10 fully covered	4 partial	0 unaddressed
GDPR Article 30	PIIGuard audit log	HMAC-signed	append-only
EU AI Act Article 13	Transparency layer	85 patterns	auditable
DestructiveGuard	15 / 15 test cases	17 patterns	CRITICAL+HIGH
PIIGuard	11 / 11 test cases	30 patterns	GDPR Art.30
OutputInjectionGuard	12 / 12 test cases	32 patterns	LLM02 covered

CANNOT_MUTATE - These guards are module-level constants.

No agent output, no system prompt override, no creative framing can modify or bypass the pattern registry.

Every block is signed with HMAC-SHA256. Every detection is written to the review queue. Every PII redaction is audited.